mentioned in table 11.2, Nginx sets the header `ssl-client-verify` to the value `SUCCESS` if the certificate was valid and signed by a trusted CA, so you can use this to decide whether to trust the client certificate.

> **WARNING** If a client can set their own `ssl-client-verify` and `ssl-client-cert` headers they can bypass the certificate authentication. You should test that your ingress controller strips these headers from any incoming requests. If your ingress controller supports using custom header names, you can reduce the risk by adding a random string to them, such as `ssl-client-cert-zOAGY18FHbAAljJV`. This makes it harder for an attacker to guess the correct header names even if the ingress is accidentally misconfigured.

You can now enable client certificate authentication by updating the `authenticate` method to check for a valid client certificate and extract the subject identifier from that instead. Listing 11.7 shows the changes required. Open the UserController.java file again and add the lines from the listing to the `authenticate` method and save your changes.

Listing 11.7 Enabling client certificate authentication

```
public void authenticate(Request request, Response response)
{
    if ("SUCCESS".equals(request.headers("ssl-client-
verify"))) {     #A
        processClientCertificateAuth(request);    #A
        return;     #A
    }
    var credentials = getCredentials(request);     #B
    if (credentials == null) return;
```